

BEACON LABS

CYBERSECURITY EDUCATION LABS

Workshop



BOISE STATE UNIVERSITY

COLLEGE OF ENGINEERING

Department of Computer Science

Table of Contents

Overview	3
Setup	3
Network Security: Middlebox Amplification Attack	4
Overview	4
Task Set 1: Amplification Types	6
Task 1.1: Identify the Amplification Type	6
Task Set 2: MiddleBox Amplification	7
Task 2.1: Running the Program	8
Task 2.2: Interacting with the Program	9
Task Set 3: Bayesian Nash Equilibrium	11
Task 3.1: Understanding Bayesian Nash Equilibrium	11
Task 3.2: Applying Bayesian Nash Equilibrium with an Exercise ...	13
Summary	14
Note	14
References	14

Overview

In this workshop, students will explore various attack strategies and vulnerabilities, focusing on network, mobile, and web threats. The hands-on activities will cover:

- **Reflection-Based Attacks:** Understanding five types of TCP-based reflection attacks and how they differ from traditional UDP-based ancestors.
- **Mobile Security Exploits:** Examining vulnerabilities within the Android API, including weaknesses in the Android Activity Lifecycle, and implementing a deceptive overlay attack to gain unauthorized access to financial transactions.
- **Cross-Site Scripting (XSS) and Service Worker Exploits:** Learning about Service Worker Cross-Site Scripting (SW-XSS) attacks, how they escalate traditional XSS threats, and simple strategies to mitigate them.

By the end of this workshop, participants will be able to analyze, implement, and defend against various cyber threats, gaining practical insights into modern attack vectors and security countermeasures.

Setup

Refer to the distributed setup instruction manual.

Network Security: Middlebox Amplification Attack

Overview

Objective

Further understand the 5 types of reflection-based attacks performed in this activity using TCP instead of UDP.

TCP-based Reflection Attacks

Reflection amplification attacks were thought to only be possible through UDP because there was no three-way handshake that took place. However, this type of attack was found to be possible through TCP in 2021 due to the existence of middleboxes, such as firewalls, that capture traffic before the server can respond to it.

Without a three-way handshake, the server should just drop unrecognized packets. Instead, the middlebox attempts to respond to the request before the server sees it. These middleboxes are often firewalls that attempt to respond to forbidden requests with blocked pages, but their response can be large, even up to an infinite number of packets, relative to the one initial request. These attacks seek to exploit that vulnerability.

Packet Schemes and Amplification Factors

Different packet schemes produced different responses from the middleboxes resulting in large or small amplification factors as seen in Figure 1 below.

Moreover, the type of forbidden page that was requested produced a different response as demonstrated in Table 1.

Strategy	Response %	Max Amplification
⟨SYN; PSH+ACK⟩	69.5%	7,455×
⟨SYN; PSH⟩	65.7%	24×
PSH	44.6%	14×
PSH+ACK	33.1%	21×
SYN (with GET)	11.4%	572×

Figure 1: Packet Type Response

URL	SYN	PSH	PSH+ACK	⟨SYN; PSH⟩	⟨SYN; PSH+ACK⟩
www.youchange.com	116,120	67,503	78,830	92,765	97,689
roxy-palace.com	128,843	52,168	63,080	86,010	97,213
plus.google.com	39,177	27,815	24,827	54,916	63,090
bittorrent.com	33,187	19,171	24,682	34,748	193,754
survive.org.uk	98,038	14,600	13,060	45,353	43,927
example.com	28,909	15,669	15,911	46,469	27,962
empty	65	27	49	42	59

Table 1: Number of IP addresses with amplification factor over 100x for each combination of target URL and packet sequence. Bolded is the maximum value for each sequence.

Types of Middlebox Amplification

There are five types of amplifications that can be produced through this method of attack:

1. Destination Reflection

- (a) Direct response of static size from the destination.
- (b) Example: 2Mb response to a 1Mb ping.

2. Middlebox Reflection

- (a) Initial ping of packet size 1Mb receiving a block page of static size 10Mb (10x Amplification).

3. Destination and Middlebox Reflection

- (a) A combination of the first two methods: A static size middlebox and destination response.

4. *Routing Loop Reflection*

- (a) All routers that a packet travels through will produce a middlebox response and loop back to each other.
- (b) Amplification increases by the number of times routers trigger the middlebox.

5. *Victim-sustained Reflection*

- (a) Packets sent to the victim computer are responded to, prompting another response from the destination.
- (b) Possible to produce an infinite amplification factor.

Resources

Reading the following paper is not mandatory but will provide a deeper understanding of this attack and its outcomes:

Paper detailing the attack: <https://www.usenix.org/system/files/sec21-bock.pdf> ^[1]

Task Set 1: Amplification Types

Objective

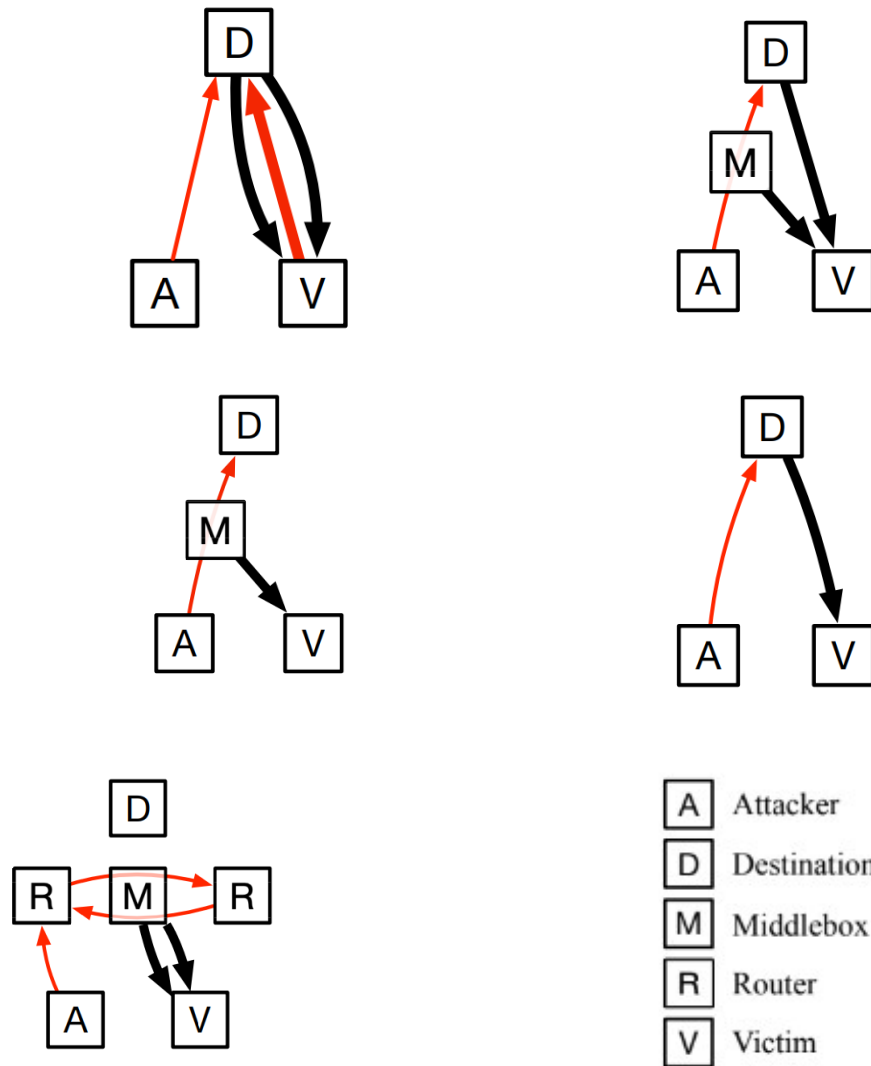
Acquire the ability to accurately identify the amplification type produced by an attack.

Task 1.1: Identify the Amplification Type

Based on the descriptions of the different types of amplifications provided in the Overview section, indicate which type of amplification each diagram below illustrates.

Action

1.1.1 - Match the diagrams below to its corresponding type of amplification.



Task Set 2: MiddleBox Amplification

Objective

Classify IP addresses depending on what type of reflection was produced.

This program will not actually send out packets to these IP addresses. The program is simply a simulation of the responses that would likely occur

when this attack is executed properly.

Task 2.1: Running the Program

To start the program, open the "Middlebox-VM" virtual machine. The login credentials are both the word "middlebox" in lowercase. Once logged in, open a terminal and in the home directory execute the following command: `middlebox`. Figure 2 shows the starting screen when running the program, and Figure 3 shows how packets can be altered before being sent out.

Action

2.1.1 - Start the program and choose to use 2 packets.

```
Welcome to the TCP Reflected Amplification Lab
////////////////////////////////////

In this lab you will need to use the tools provided to reveal and identify each of the 5 types of TCP amplification attacks.
You will be performing actions as an "attacker" and observing the feedback as the "victim". If you get stuck, the article
may provide the information you need. Be sure to save and submit the results from your terminal.

Welcome to the packet configuration system!
Would you like to use one (1) or two (2) packets in your next attack?
```

Figure 2: Program start screen

```
What packet value(s) you like to set?
0)Set HTTP Header
1)Set Flag(s)
2)Set TTL (time to live)
3)Adjust Packet Optional Size
4)Adjust Packet Payload Size
5)View Current Packet Configuration
6)Learn More About Packet Configuration
7)Close Packet Configuration (will print the resultant configuration)
```

Figure 3: Packet creation module with different options for changing that packets that will be sent.

Within the program, you should first craft what kind of packet you want to send out. This requires setting the HTTP header, flags, time to live (TTL), and adjusting the size of the packet and payload to be sent. Using the crafted packet, you can then perform a wide attack, targeted attack, or a traceroute.

If you are unsure of what flags or header to use, hints can be found in Figure 1 and Table 1 in the Overview section.

Action

2.1.2 - Choose to set the HTTP Header and enter "youchange.com" as the domain name.

2.1.3 - Choose to set the Flag(s) and set the appropriate flags you want to set.

2.1.4 - Choose to set the time to live (TTL) and choose the longest possible time.

2.1.5 - Choose to adjust packet optional size and choose the default size.

2.1.6 - Choose to adjust the packet payload size and choose the default size.

2.1.7 - View your packet configuration and then close the packet configuration once you're satisfied.

Task 2.2: Interacting with the Program

A Wide attack will send your packet to all IPs and show how many packets were sent in response. A Targeted attack will allow you to send your packet to one IP and observe how many packets are sent in response.

A traceroute will show the path a packet takes on the way to its destination. This will be useful in identifying what kind of amplification took place. **Some of the traceroutes will look identical, but based on the number of packets in response you should be able to identify what type of reflection it is, if there is reflection at all.**

```
Please select an action from the following list:
0) Configure your packet(s)
1) View your current packet configuration(s)
2) Perform an IPV4 wide attack
3) Perform an targeted attack
4) Perform a Traceroute
5) Complete the quiz?
```

Figure 4: All actions that can be performed in the program.

All tools listed in Figure 4 are required to complete the activity with full points.

The following table shows everything that needs to be identified for the quiz.

Quiz Question	Point Value	Total
Which IPs produced amplification? (5x)	8	40
Which type of amplification is at each IP? (5x)	5	25
Destination response size	5	5
Middlebox response size (2x)	5	10
Number of routers in routing loop	10	10
How many packets did the victim send in the victim-sustained attack?	10	10

Keep track of these things as you work through the program. The quiz will ask you these questions and you can gain points for each. (*Hint for the final question: Assume the victim sent one packet to the server in response to each server packet*)

Remember, not all combinations of packets will result in all attacks being performed. You may need to reconfigure the packet(s) in order to find all of the attacks.

Each question will have a set number of attempts in case you mistype your answer. Additionally, you can run the program again to generate new IPs for each amplification and attempt to gain a better score.

Action

2.2.1 - Complete an IPv4 wide attack and note down the 5 IP addresses that resulted in an amplification attack. If you don't see 5, try a different packet configuration.

2.2.2 - For each of the 5 IP addresses, perform a Traceroute and save the results.

2.2.3 - Complete the quiz.

2.2.4 - Open a browser and navigate to the feedback form that's provided to you after completing the quiz. **Please wait to complete the quiz until completing Task Set 3.** Any and all feedback is greatly appreciated!

Task Set 3: Bayesian Nash Equilibrium

Objective

Further comprehend the Bayesian Nash Equilibrium through analysis of a Game Theory table and application of the concept to a hypothetical scenario.

Task 3.1: Understanding Bayesian Nash Equilibrium

Game theory can be applied to more than just a two party situation. Deciding which action should be taken when there is uncertainty of the other party can be solved with Bayesian Nash Equilibrium. Keep in mind, **Bayesian Nash equilibrium only works when no one has incentive to change their strategy based on prior beliefs of the other party.**

Bayesian Nash Equilibrium will be demonstrated on Table 2, then you will apply it to the made-up scenario following Table 2.

		Player 2 A-Type		Player 2 B-Type	
		Left	Right	Left	Right
		Up	Down	Up	Down
Player 1	Up	(6, 2)	(0, 4)	(3, 4)	(1, 0)
	Down	(5, 1)	(-1, 4)	(4, 3)	(2, 0)

Table 2: Game Theory Example

There is a chance that Player 1 will be either A-Type or B-Type. We will represent this with the variable P . There are still only two options for both players to choose but, Player 2 does not know what type Player 1 is. Furthermore, Player 1 can only see the table corresponding to their type while Player 2 can see both tables.

Player 2 must first see what the dominant strategy is for Player 1 in each scenario. This is quite simple though as with A-Type, Up strictly dominates Down, and for B-Type, Down strictly dominates Up. With this information, the table Player 2 is working with now looks like Table 3.

		Player 2		Player 2		
		A-Type		B-Type		
		Left	Right	Left	Right	
Player 1	Up	(6, 2)	(0, 4)	Up		
	Down			Down	(4, 3)	(2, 0)

Table 3: Game Theory Example

Next we must calculate the utility of each action. What can Player 2 gain if they were to play left or right?

Remember that P is the probability of Player 1 being an A-Type. Thus, $1 - P$ is the probability of Player 1 being a B-Type. To calculate the utility of Player 2 playing left, we take the utility from choosing left on both types times the probability of being that type. The same symbolic calculation was done to calculate the utility of Player 2 playing right.

$$\text{LEFT: } 2P + 3(1 - P)$$

$$\text{RIGHT: } 4P + 0(1 - P)$$

By solving an inequality we can see when Player 2 should play left or right.

$$2P + 3(1 - P) > 4P + 0(1 - P)$$

$$2P + 3 - 3P > 4P$$

$$3 - P > 4P$$

$$3 > 5P$$

$$\frac{3}{5} > P$$

So when P is less than $\frac{3}{5}$, Player 2 should play left, but when P is greater than or equal to $\frac{3}{5}$ they should play right.

Task 3.2: Applying Bayesian Nash Equilibrium with an Exercise

Use the concepts learned in Task 3.1 to answer the questions in Task 3.2.

		Attacker A-Type	
		New Attack	Old Attack
Server	No one watching server	(1, 5)	(2, 3)
	Someone watching server	(3, 4)	(2, 2)
		Attacker B-Type	
		New Attack	Old Attack
Server	No one watching server	(2, 2)	(3, 3)
	Someone watching server	(1, 1)	(2, 1)

Table 4: Game Theory Task

Let's say that there are two countries that you want to use this new attack on. Country 1 is the primary target and Country 2 is an ally. The server you are attacking is a server positioned on the shared border of the two countries so, there is a chance that it could be administered by either.

You could either use an old attack so that they are unaware of the new vulnerability, but it may be less effective, or, you could use this new attack with which you could do more damage, but be unable to use it in the future as the vulnerability was patched.

The A-Type server is Country One (the primary target), and B-Type is Country Two (the ally). Using these tables, answer the following questions:

Action

3.2.1 - Write your inequalities.

3.2.2 - Solve your inequalities.

3.2.3 - Answer the following questions.

Which attack should you use if there is a $\frac{1}{2}$ chance the server is owned by country one?

Which attack should you use if there is a $\frac{1}{3}$ chance the server is owned by country one?

Which attack should you use if there is a $\frac{1}{4}$ chance the server is owned by country one?

3.2.4 - Navigate back to your browser and complete the survey.

Summary

Reflection based attacks have been common over UDP but, this is the first time they have been possible over TCP. This activity has taught you about the kinds of middlebox reflections and how to identify them.

TCP reflection based attacks are a large vulnerability that has major ramifications across many nations who have a high amount of censorship. To learn the extent of this vulnerability, the paper^[1] is listed in both the Overview and References section.

Note

One of the domains that is in the paper was deemed inappropriate for educational settings and was changed from its original name to "youchange" to better fit educational settings.

References

- [1] Kevin Bock, Abdulrahman Alaraj, Yair Fax, Kyle Hurley, Eric Wustrow, and Dave Levin. Weaponizing middleboxes for TCP reflected amplifi-

cation. In *30th USENIX Security Symposium (USENIX Security 21)*, pages 3345–3361. USENIX Association, August 2021.